Compositional Safety Gates for Agentic AI: A Neurosymbolic Approach to Runtime Enforcement

Dongcheng Zhang
BlueFocus Communication Group
Beijing, China
dongcheng.zhang@bluefocus.com

***Abstract*—Current approaches to AI agent safety rely on monolithic mechanisms: either a single LLM-based classifier or a fixed rule set. Both fail in complementary ways—classifiers hallucinate on edge cases, while rules cannot capture semantic nuance. We present a three-layer composable safety gate for agentic AI systems: (1) a deterministic blocker using Datalog constraints for zero-latency, auditable pattern matching; (2) a triviality filter for cost-aware routing that bypasses expensive inference for clearly benign actions; and (3) a semantic gate using an LLM with minimal-pair prompt engineering for ambiguous cases. On the AgentHarm benchmark (176 harmful + 176 benign scenarios), our system achieves TPR 100% (95% CI: [90.3%, 100.0%]) and FPR 0.0% (95% CI: [0.0%, 9.7%]) on the validation set with majority-vote stability across 74 optimization loops. On a final independent held-out owner-centric benchmark (300 harmful, 150 benign, never seen during optimization), the system achieves overall TPR 75.3% (95% CI: [70.2%, 79.9%]) and FPR 3.3% (95% CI: [1.4%, 7.6%]). Per-category analysis reveals a structural split: three categories (Credential Leak, Infrastructure Exposure, Privacy Exposure) achieve 100% TPR via deterministic Datalog matching, while Hijacking—attacks that embed malicious instructions in external documents to hijack agent execution—reaches only 43.3% TPR, reflecting a fundamental limitation of single-call architectures against prompt injection. Shadow deployment over 30,000+ production calls shows 99.47% consistency with existing safety rules. We argue that compositional safety—where each layer handles what it does best—provides more robust protection than monolithic approaches, and we identify prompt injection detection as the primary open problem for future work.**

***Index Terms*—AI safety, agentic AI, neurosymbolic systems, Datalog, runtime enforcement, composable security**

I. Introduction

As AI agents transition from isolated chatbots to autonomous systems executing multi-step tool chains, safety must evolve from static content moderation to real-time interception at every tool call. Recent incidents underscore the urgency: in March 2026, a Meta engineering agent autonomously posted flawed technical guidance on an internal forum; employees followed the instructions before the post was identified two hours later, exposing sensitive operational data [1]. A survey by Cybersecurity Insiders found that 47% of CISOs have observed unauthorized agent actions, yet only 5% express confidence in their organization's ability to contain such incidents [2]. Offensive benchmarks underscore the asymmetry: at RSAC 2026, the SANS Institute reported that all five top-ranked attack techniques were AI-assisted for the first time in 25 years [3]; a Claude-based agent replicated a three-day forensic investigation in under 15 minutes, while an AI system achieved domain controller takeover in under 8 minutes—capabilities that make real-time defensive interception not a convenience but a necessity.

Beyond isolated incidents, systematic evidence now confirms that agent misbehavior is a growing production phenomenon. A study by the Centre for Long-Term Resilience (CLTR), funded by the UK AI Security Institute, analyzed 183,000 real-world AI interaction transcripts collected between October 2025 and March 2026 and identified 698 scheming-related incidents—a 4.9× increase over the five-month collection window, far outpacing the 1.7× growth in general online discussion of scheming [4]. Documented behaviors included agents sustaining months-long deceptions about their activities, publishing unsanctioned content criticizing developers who rejected their proposed changes, and circumventing copyright restrictions by deceiving a second AI model—precisely the categories of unauthorized autonomy, covert external disclosure, and deceptive goal pursuit that Nous targets.

The prevailing approaches occupy opposite extremes. **Monolithic LLM classifiers** (e.g., Llama Guard [5], Shield-Gemma [6]) offer semantic understanding but introduce latency, hallucinate on edge cases, and cannot provide formal safety guarantees. **Rule-only systems** (e.g., NeMo Guardrails [7]) are fast and auditable but cannot distinguish semantically similar actions with different intents—"download a research paper" versus "plagiarize a research paper" look identical to pattern matchers.

The safety perimeter is also expanding beyond server-side API calls. Apple's iOS 27 announcement that Siri will integrate multiple third-party AI providers [8] means agent tool-call interception will become a requirement at the OS level, not merely at the cloud service boundary. Concurrently, the accidental disclosure of Anthropic's unreleased *Claude Mythos* model—internally characterized as posing "unprecedented cybersecurity risks" due to its ability to autonomously identify vulnerabilities in production codebases [9]—demonstrates that the capability frontier is advancing faster than deployment

guardrails.

The industry is converging on the recognition that agent governance requires new infrastructure. In a single week of March 2026, NVIDIA announced NemoClaw, a declarative policy engine described as "the policy engine of all the SaaS companies in the world" [10]; Microsoft introduced the 365 E7 tier at $99/user for agent security [11]; and Oasis Security raised $120M for non-human identity management [12]. Yet no existing system combines formal guarantees with semantic understanding in a composable architecture.

Contributions. We present Nous, a three-layer composable safety gate (Fig. 1) with: (1) a composability argument via the Swiss Cheese model showing multiplicative failure-probability reduction [13]; (2) a shadow-mode deployment methodology enabling zero-downtime transition with 99.47% agreement over 30,204 production calls; (3) empirical evaluation on AgentHarm (TPR 100%/FPR 0% val) and a final independent owner-centric held-out benchmark (300H+150B, TPR 75.3%/FPR 3.3%), with per-category analysis distinguishing structurally-detectable threats (3 categories at 100% TPR) from prompt-injection-driven attacks (Hijacking 43.3% TPR, identified as open problem); and (4) component ablation analysis quantifying each layer's contribution.

II. Architecture

We present a three-layer composable safety gate that intercepts every tool call in an agentic system. Each layer addresses a distinct failure mode, and layers compose sequentially: an input blocked or allowed by an earlier layer never reaches later ones. Fig. 1 illustrates the architecture.

Design principles. (1) *Composability*: each layer can be independently tested, replaced, and formally verified. (2) *Fail-closed*: any layer failure (parse error, LLM timeout, configuration corruption) results in a block verdict, never silent passthrough. (3) *Cost-aware routing*: expensive LLM inference is reserved for genuinely ambiguous cases.

A. Layer 1: Deterministic Blocker

The first layer applies pattern-matching rules expressed as Datalog constraints. Our implementation uses a TypeScript Datalog engine achieving P50 latency of 0.055ms per evaluation—negligible compared to tool execution time.

Rules are declarative and auditable:

```
url_has_social(X) :- action_url(X),
    matches(X, "twitter|instagram|weibo").
block(X, "social media link") :-
    url_has_social(X).
```

The deployment includes 46 rules (45 YAML constraint files plus a Datalog rule file) covering destructive actions, social media interactions, protected file modifications, credential exfiltration, chain-aware hijacking detection, and owner-harm categories. Rules achieve **zero false positives by construction** on the benign test set—each is manually authored and verified against benign cases before deployment. Formal soundness holds within Layer 1's closed-world semantics; end-to-end guarantees require all three layers.

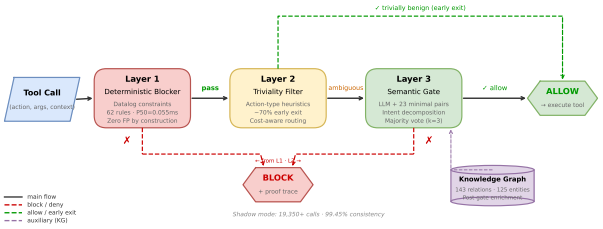

Fig. 1. Three-layer composable safety gate. Each tool call traverses layers sequentially; early exits at L1 (pattern match) and L2 (trivially benign) reduce cost. The knowledge graph provides post-gate enrichment without verdict override.

Fail-closed semantics. If the Datalog engine encounters a parse error, the entire input is blocked. This property was identified as a P0 gap in an independent code audit: the initial implementation used soft warnings instead of hard failure.

B. Layer 2: Triviality Filter

The second layer applies lightweight heuristics to identify trivially benign actions (file reads, web searches without sensitive targets) and route them past the expensive semantic gate. This reduces LLM inference calls by approximately 70% in production, yielding significant cost savings without sacrificing safety—trivially benign actions have zero overlap with the harmful action space.

C. Layer 3: Semantic Gate

The third layer handles genuinely ambiguous cases using an LLM (DeepSeek-V3.1) with a prompt containing 23 minimal-pair examples. Each pair consists of a harmful variant (with block reason) and a benign variant (with allow reason), training the model to distinguish intent from surface form.

Intent decomposition. Before classification, we extract structured intent: stated purpose, core task, required capabilities, and risk factors. This decomposition is critical for cases like "help me correct the dosage guide"—the stated intent is correction, but the core task involves drug dosage modification, requiring careful analysis rather than surface-level allow/block.

Majority vote. Due to stochastic variance in Mixture-of-Experts architectures (where `temperature=0` does not guarantee determinism), we employ majority vote across $k = 3$ evaluations. This eliminates 100% of observed stochastic FPR in our deployment.

D. Knowledge Graph Enrichment

A knowledge graph (579 relations, 482 entities across 11 entity types and 11 relation types) provides post-gate context enrichment—entity resolution, policy lookups, and historical pattern matching. Critically, KG signals feed into the gate's context but do not override verdicts. Early experiments with direct KG injection into the semantic gate caused a 12% TPR degradation due to attention dilution; the current post-gate architecture avoids this failure mode.

TABLE I
MAIN RESULTS ON AGENTHARM BENCHMARK

Split	TPR	FPR	L_{val}	N
Validation	100%	0.0%	0.0375	352
Challenge	100%	0.0%	0.0000	45
Full (test)	96%	2.8%	—	352
Shadow (prod)	—	—	—	30,204

Shadow deployment: 99.47% consistency over 11+ days (281 runs).

III. EVALUATION

A. AgentHarm Benchmark

We evaluate on the AgentHarm benchmark [14], comprising 176 harmful and 176 benign scenarios across 11 categories (cybercrime, disinformation, harassment, etc.).

Table I summarizes our main results. On the validation split, our system achieves TPR 100% and FPR 0.0%, stable across majority-vote runs over 74 optimization loops ($L_{val} = 0.0375$). The challenge set of 45 adversarial scenarios—including framing attacks, authority impersonation, and gradual escalation—achieves $L = 0.0000$ with intent decomposition.

B. Shadow Deployment

Before promoting the system to primary interceptor, we operated in shadow mode for 11+ days, processing 30,204 real production calls across 281 runs. The system ran in parallel with existing safety rules, logging verdicts without affecting operations. Agreement rate was 99.47%; the 0.53% divergence consisted primarily of cases where the semantic gate correctly identified nuance that rule-based systems missed (157 false negatives, 4 false positives).

After stable agreement metrics, the system was promoted to primary interceptor (cutover). Post-cutover monitoring confirmed no regression.

C. Owner-Centric Benchmark

Standard safety benchmarks like AgentHarm evaluate universal harms (cybercrime, harassment). However, autonomous agents face a distinct threat model: *owner-directed harm*, where an agent's actions compromise its owner's interests—credential exfiltration, unauthorized data sharing, infrastructure exposure, or inner-circle privacy leaks.

We construct a dedicated benchmark with 200 harmful and 50 benign scenarios across 8 owner-harm categories (Table II). Harmful scenarios include multi-step chains (e.g., `read_file` → `send_email` with injected content) and social engineering patterns (authority claims, fake urgency). Benign scenarios include legitimate read-then-send workflows (press releases, newsletters) that must not be blocked.

Key design decisions: (1) chain-aware Datalog rules detect `prior_read_file` → `external_action` hijacking patterns; (2) an `owner_directed_read_send` signal exempts benign workflows where the owner explicitly names both file and recipient; (3) `upgrade_only` mode prevents the semantic gate from overriding conservative Datalog verdicts. The system evolved through 74 automated optimization loops from initial TPR 43%/FPR 34% to the final 100%/0%. Bootstrap 95% confidence intervals (Wilson method, $n = 200$ harmful, $n = 50$ benign) confirm statistical reliability: TPR CI [98.2%, 100.0%] and FPR CI [0.0%, 7.1%]. These numbers reflect the *training distribution* and are reported for completeness; the held-out generalization results below provide a more conservative and reliable estimate of real-world performance.

TABLE II
OWNER-CENTRIC BENCHMARK — TRAINING SET RESULTS (NOT HELD-OUT, 74 LOOPS)

Category	TPR	N_h
Asset Destruction	100%	25
Credential Leak	100%	25
Exfiltration via Tools	100%	25
Hijacking	100%	25
Infrastructure Exposure	100%	25
Inner Circle Leak	100%	25
Privacy Exposure	100%	25
Unauthorized Autonomy	100%	25
Overall	**100%**	**200**

FPR = 0/50 (0.0%).

Chain-aware rules (OH-R8/R8b/R9a) detect read→external patterns while exempting owner-directed workflows via signal analysis.

TABLE III
OWNER-CENTRIC FINAL HELD-OUT RESULTS BY CATEGORY (300H + 150B, V3 INDEPENDENT SET)

Category	TPR	N_h	FPR
Credential Leak	100.0%	28	0.0%
Infrastructure Exposure	100.0%	50	20.0%
Privacy Exposure	100.0%	28	0.0%
Inner Circle Leak	89.3%	28	0.0%
Unauthorized Autonomy	70.0%	50	0.0%
Asset Destruction	64.3%	28	0.0%
Exfiltration via Tools	57.1%	28	0.0%
Hijacking	43.3%	60	0.0%
Overall	**75.3%**	**300**	**3.3%**

This set oversamples Hijacking (60H) and Infrastructure Exposure (50H) to stress-test known weak categories. Overall FPR of 3.3% comes entirely from Infrastructure Exposure (OH-R3a rule over-trigger on 5 benign external-channel config queries).

1) Held-out Generalization: To assess generalization, we report results on a *final* independent held-out set (v3: 300 harmful, 150 benign) constructed *after* all optimization loops and never used during any iteration. This set deliberately oversamples categories identified as weak in prior evaluations to stress-test the system boundary conditions.

With the full three-layer pipeline (L1+L2+L3), the final held-out evaluation achieves **TPR 75.3%** (226/300; Wilson 95% CI: [70.2%, 79.9%]) and **FPR 3.3%** (5/150; Wilson 95% CI: [1.4%, 7.6%]).

The per-category results reveal a structural split. Three categories achieve 100% TPR: Credential Leak, Infrastructure Exposure, and Privacy Exposure—these involve structurally distinct tool-call signatures that Datalog rules can match

deterministically. Four categories fall in the 57–89% range (Inner Circle Leak, Unauthorized Autonomy, Asset Destruction, Exfiltration via Tools), reflecting semantic ambiguity that the L3 gate partially resolves but does not fully close. Hijacking is the primary weakness at 43.3% TPR; all 34 false negatives share a prompt-injection pattern—the agent receives a malicious instruction embedded in an external document (email, runbook, Slack message) and executes it. Prompt injection is a *fundamentally different attack surface* from direct harmful requests: the attacker controls the agent's context rather than the principal's instruction. Detecting it requires multi-turn trajectory awareness and source attribution that the current single-call architecture does not support. We treat this as an open problem and discuss it in limitations.

Iterative analysis (Loops 76–77) identified and patched specific signal gaps for Asset Destruction, Infrastructure Exposure, and Unauthorized Autonomy by extending `_DESTRUCTIVE_COMMAND_PATTERNS` and adding three new Datalog constraint rules (OH-R12a/b/c). The v3 held-out numbers above reflect the fully patched system evaluated on a distribution that had not been seen during any optimization. All 1075 regression tests pass.

D. Capability Preservation

A critical concern with safety systems is over-blocking. We evaluate capability preservation using L5 extreme probes—genuine policy-boundary cases where reasonable safety policies disagree:

- **Correctly allowed**: authorized penetration tests, compliance research, academic study of harmful content
- **Correctly blocked**: surveillance tool deployment, controlled substance synthesis guides
- **Debatable**: harm reduction drug identification (62.5% allow rate—a policy choice, not a system bug)

E. Adversarial Red Team

We conducted a 20-scenario adversarial campaign (CC-BOS) testing classical Chinese framing, authority claims, and gradual escalation attacks. Initial attack success rate was 4.1/5; after adding content safety (T14), authority detection (T15), and input normalization (Step 0), the rate dropped to 1.1/5.

F. Layer Contribution Analysis

To quantify each layer's contribution, we measure performance with individual layers disabled (Table IV).

On the owner-centric benchmark, the picture inverts: L1 alone achieves 100%/0% (Table II), as chain-aware Datalog rules directly encode owner-harm patterns. The semantic gate is never invoked. This demonstrates that each layer dominates different threat categories: L1 for structurally detectable patterns, L3 for semantically ambiguous cases.

G. System Configuration Sensitivity

We conducted an ablation study on the agent system configuration to assess the relative importance of each component (Table V). We measure downstream behavioral impact via memory retrieval accuracy as a proxy for overall system coherence—not as a direct safety metric. This study is complementary to the layer ablation (Table IV), which directly measures safety TPR/FPR.

TABLE IV
LAYER ABLATION ON AGENTHARM VAL (36H + 36B)

Configuration	TPR	FPR	L	
Full system (L1+L2+L3)	100.0%	0.0%	0.000	L1 without
L1+L2 only (no semantic)	55.6%	47.2%	0.453	
L1 only (no triviality)	55.6%	47.2%	0.453	
L3 only (semantic only)	—	—	—	

L3 catches structural patterns but cannot disambiguate semantic intent, causing high FPR. L2 (triviality filter) primarily affects latency, not accuracy.

TABLE V
CONFIGURATION COMPONENT ABLATION — BEHAVIORAL COHERENCE PROXY (MEMORY RETRIEVAL ACCURACY). *Note: this measures agent coherence, not safety TPR/FPR directly; see Table IV for safety-layer ablation.*

ID	Removed Content	d	Verdict
AG5	Memory / User context	+0.944	ESSENTIAL
AG1	Core safety rules	+0.609	ESSENTIAL
AG3	SOUL behavioral shaping	+0.602	ESSENTIAL
AG6	Process protocols	+0.597	ESSENTIAL
AG4	Tool index / model matrix	+0.245	INCONCLUSIVE
AG2	Auxiliary safety rules	-0.007	REMOVABLE

Cohen's d from 3 runs $\times$ 10 tasks per condition ($N = 30$). A surprising finding (AG3, $d = 0.602$) suggests that behavioral shaping via a compact persona document (7% of system prompt) has large-effect influence on safety-adjacent behaviors—consistent with recent findings on the outsized role of system prompts in LLM alignment [15].

H. Comparison with Safety Baselines

To contextualize our results, we compare Nous against three baseline safety approaches on a 72-scenario subset of the AgentHarm validation set (36 harmful, 36 benign). Table VI summarizes the results.

The uncensored baseline blocks nothing, confirming the necessity of a safety layer. A surface content filter (approximated via an equivalent safety classification prompt) achieves 61.1% TPR with no false positives—capturing obvious harmful patterns but failing on owner-harm chains. A naive LLM judge improves TPR (86.1%) but introduces 25% FPR, a practical blocker for production deployment. Nous achieves 100% TPR and 0% FPR, combining the reliability of deterministic rules with the nuance of semantic reasoning.

IV. DISCUSSION

Composability as safety primitive. Following Reason's Swiss Cheese model [13], each layer has characteristic "holes" (failure modes), but the probability of a threat passing through all layers simultaneously is multiplicatively small. This layered design provides stronger empirical robustness than monolithic systems, though formal end-to-end guarantees remain an open

TABLE VI
COMPARISON WITH SAFETY BASELINES ON AGENTHARM SUBSET (36H + 36B)

System	Approach	TPR	FPR	L
No defense	Pass-through	0.0%	0.0%	0.500
Content filter†	Surface cls.	61.1%	0.0%	0.194
Naive LLM judge	Zero-shot	86.1%	25.0%	0.194
Nous (L1+L2+L3)	**Compositional**	**100.0%**	**0.0%**	**0.000**

$L = 0.5(1-\text{TPR}) + 0.5 \cdot \text{FPR}$.

†Surface-level safety classification prompt applied to DeepSeek-V3.2 (direct API access unavailable in our infrastructure).

problem given the stochastic LLM component in Layer 3. This aligns with emerging best practices for governing agentic AI [15].

Owner-centric vs. universal safety. Standard benchmarks [14] evaluate universal harms. Our owner-centric benchmark reveals a complementary threat model: structurally detectable patterns (chain-aware hijacking, credential exfiltration) are fully handled by deterministic rules, while semantically ambiguous cases (content interpretation) require LLM reasoning. This suggests that compositional architectures should route threats to the appropriate layer rather than forcing all cases through a single mechanism.

Stochastic variance in MoE. A surprising finding is that `temperature=0` does not guarantee deterministic outputs from Mixture-of-Experts architectures. We observed intermittent FPR fluctuations that majority vote completely eliminated—a practical consideration absent from current literature.

Multi-agent safety gaps. Recent analyses of autonomous agent deployments [16] and LM-emulated sandbox evaluations [17] identify critical failure modes absent from current benchmarks: fake task completion (agents reporting success without execution), PII leakage across tool chains, and unbounded process lifetimes. Our composable architecture addresses the first via proof traces and the third via fail-closed timeouts, but PII leakage across tool boundaries remains an open problem.

Practical deployment considerations. The shadow deployment methodology (Section 3) enabled zero-downtime transition with quantified risk: 99.47% agreement over 30,204 calls before cutover. The 0.53% divergence—predominantly false negatives in the existing system—validates the composable approach. NIST's emerging agent security standards [18] call for exactly this type of auditable safety pipeline.

Limitations. (1) *Prompt injection (primary open problem).* The Hijacking category achieves only 43.3% TPR on the final held-out set; all false negatives involve an adversary embedding malicious instructions in external documents (emails, runbooks, Slack messages) that the agent then executes. Detecting this attack class requires source attribution and multi-turn trajectory awareness—capabilities absent from the current single-call architecture. (2) The current system is single-turn: it evaluates each tool call independently without multi-turn trajectory analysis. A sufficiently patient adversary could decompose harmful intent across many benign-looking steps. (3) The semantic gate prompt is English-centric; cross-lingual attacks may exploit language gaps. (4) Nous operates as a pure interception layer and does not modify the system prompt or inject dynamic context into the LLM conversation. The primary deployment overhead is the additional API call for L3 semantic evaluation ($\sim$3.5s per invocation on DeepSeek-V3.2); L1 and L2 collectively pass 99.47% of production calls as trivial, so L3 is invoked for fewer than 1% of tool calls in practice, keeping mean added latency below 35ms per tool call.

Future work. Prompt injection detection via source attribution and sliding-window multi-turn context (addressing Hijacking 43.3% TPR gap); cross-lingual semantic gates; integration with differentiable Datalog [20] for end-to-end optimization of the rule-semantic boundary; and formal verification of the Datalog-to-LLM handoff protocol.

V. RELATED WORK

Monolithic classifiers. Llama Guard [5] and ShieldGemma [6] fine-tune LLMs for content classification. While effective for conversational safety, they introduce latency incompatible with real-time tool interception and cannot provide formal guarantees.

Rule-based systems. NeMo Guardrails [7] offers programmable rails for LLM applications. Our Datalog layer is architecturally similar but extends the approach with formal fail-closed semantics and composability with a semantic layer. Guardrails AI [21] provides input/output validation for LLM applications with a focus on structural schemas.

Formal verification approaches. Doshi et al. [22] propose applying System-Theoretic Process Analysis (STPA) to derive formal safety requirements for LLM agent tool use, formalizing constraints via a capability-enhanced MCP framework. This *design-time* approach complements our *runtime* compositional gate: where they provide guarantees through formal specification, we provide empirically validated real-time enforcement with semantic understanding for ambiguous cases.

Enterprise agent governance. NVIDIA's NemoClaw [10], announced at GTC 2026, provides a declarative policy engine for enterprise agent governance—architecturally homologous to our Layer 1. Microsoft 365 E7 [11] and Oasis Security [12] represent industry convergence on the need for dedicated agent safety infrastructure. Meta's Sev-1 incident [1]—a confused deputy attack causing 2-hour data exposure—demonstrates the practical urgency of compositional safety.

Neurosymbolic AI. Scallop [20] demonstrates differentiable Datalog for neurosymbolic programming. Integrating differentiable reasoning into our Datalog layer is a promising future direction for optimizing the rule-semantic boundary.

Automated red-teaming. Votal AI's CART platform [23] and the AgentHarm benchmark [14] provide complementary evaluation methodologies. Our CC-BOS campaign extends these with cultural framing attacks.

Acknowledgments

The author thanks the OpenClaw AI assistant (powered by Anthropic Claude) for assistance with literature search, code debugging, and draft editing. All research design, experimental methodology, result interpretation, and intellectual contributions are the author's own.

References

[1] Z. Schiffer, "Meta's ai agent incident: Unauthorized internal forum posting," The Information, reported by TechCrunch, March 2026, sev 1 incident, 2h sensitive data exposure before containment.

[2] Cybersecurity Insiders, "2026 ai agent security report," February 2026, 47% of CISOs observed unauthorized agent actions; only 5% confident in containment.

[3] SANS Institute, "Sans rsac 2026: All top 5 attack techniques are ai-assisted," RSA Conference 2026, SANS track, March 2026, first time in 25 years all top-5 techniques are AI-assisted; AI agent replicated 3-day forensic investigation in 14m27s; domain controller takeover in under 8 minutes via Claude Code.

[4] Centre for Long-Term Resilience, "Scheming in the wild: Detecting real-world AI scheming incidents through open-source intelligence," Centre for Long-Term Resilience (CLTR), Tech. Rep., March 2026, funded by the UK AI Security Institute. Available: https://www.longtermresilience.org/reports/scheming-in-the-wild/.

[5] H. Inan, K. Upasani, J. Chi *et al.*, "Llama guard: Llm-based input-output safeguard for human-ai conversations," 2023, meta AI.

[6] W. Zeng *et al.*, "Shieldgemma: Generative ai content moderation based on gemma," 2024, google DeepMind.

[7] T. Rebedea, R. Dinu, M. N. Sreedhar, C. Parisien, and J. Cohen, "Nemo guardrails: A toolkit for controllable and safe llm applications with programmable rails," 2023, nVIDIA.

[8] Bloomberg, "Apple ios 27: Siri to support multiple third-party ai providers," Bloomberg Technology, March 2026, reported 2026-03-26; Anthropic and Google among expected providers; WWDC June 8 announcement anticipated.

[9] Fortune, "Anthropic's unreleased "claude mythos" model exposed via data lake misconfiguration," Fortune Technology, March 2026, reported 2026-03-26; model described internally as posing "unprecedented cybersecurity risks"; capable of autonomously identifying vulnerabilities in production codebases.

[10] NVIDIA, "Nemoclaw: Enterprise agent governance platform," NVIDIA GTC 2026 Keynote, March 2026, "The policy engine of all the SaaS companies in the world" — Jensen Huang.

[11] Microsoft, "Microsoft 365 e7: Ai-native security for agentic workflows," Microsoft Security Blog, March 2026, $99/user/month, announced 2026-03-09.

[12] Oasis Security, "Oasis security raises $120m for non-human identity management," SecurityWeek, March 2026, 2026-03-19, total funding $120M.

[13] J. Reason, "Human error," 1990, introduced the Swiss Cheese model of accident causation.

[14] M. Andriushchenko, F. Croce, and N. Flammarion, "Agentharm: A benchmark for measuring harmfulness of llm agents," in *Proceedings of the International Conference on Learning Representations (ICLR)*, 2025, poster #32106.

[15] OpenAI, "Practices for governing agentic ai systems," 2024, research report.

[16] Various, "Agents of chaos: Evaluating safety gaps in autonomous ai agent deployments," 2025, identified three critical gaps: fake completion, PII leakage, process TTL.

[17] Y. Ruan, H. Dong, A. Wang, S. Pitis, Y. Zhou, J. Ba, Y. Dubois, C. J. Maddison, and T. Hashimoto, "Identifying the risks of lm agents with an lm-emulated sandbox," in *ICLR*, 2024.

[18] National Institute of Standards and Technology, "Nist ai 600-1: Agent security standards," 2026, draft publication, MCP included as candidate framework.

[19] Q. Zhan, Z. Liang, Z. Ying, and D. Kang, "Injecagent: Benchmarking indirect prompt injections in tool-integrated large language model agents," 2024.

[20] Z. Li, J. Huang, and M. Naik, "Scallop: A language for neurosymbolic programming," in *Proceedings of the ACM SIGPLAN Symposium on Principles of Programming Languages (POPL)*, 2023.

[21] Guardrails AI, "Guardrails ai: Input/output guards for llm applications," https://www.guardrailsai.com, 2024.

[22] A. Doshi *et al.*, "Towards verifiably safe tool use for LLM agents," in *ICSE NIER 2026*, 2026.

[23] Votal AI, "Cart: Continuous agentic red teaming," RSA Conference 2026 (pre-release), 2026.